



中华人民共和国通信行业标准

XX/T XXXXX—XXXX

移动智能终端人脸识别安全技术要求及测试评估方法

Security technical requirements and test evaluation methods for face recognition of
smart mobile terminal

点击此处添加与国际标准一致性程度的标识

(报批稿)

XXXX – XX – XX 发布

XXXX – XX – XX 实施

中华人民共和国工业和信息化部
布

发

目 次

前言..... II

引言..... III

1 范围..... 1

2 规范性引用文件..... 1

3 术语、定义和缩略语..... 1

4 移动智能终端人脸识别架构..... 3

5 性能要求..... 4

6 安全技术要求..... 4

7 测试评估方法..... 6

8 评估与分级..... 19

附 录 A..... 21

参考文献..... 22

前 言

本文件按照 GB/T 1.1-2020给出的规则起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别这些专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院，西安交通大学，OPPO广东移动通信有限公司，蚂蚁科技集团股份有限公司，高通无线通信技术(中国)有限公司，北京三星通信技术研究有限公司。

本文件主要起草人：傅山，刘陶，沈超，蔺琛皓，路晔绵，王嘉义，宁华，王艳红，吴怡，杨萌科，李腾，林冠辰，马志远，王江胜，吴越。

引 言

近年来,随着人工智能领域和光学成像器件的突飞猛进,在移动终端上实现的本地人脸识别技术基于这些先进的算法和硬件基础快速发展,移动智能终端厂商纷纷在产品中加入本地人脸识别功能,进一步推动了人脸识别技术在移动金融、安防、移动互联网领域中的应用。与此同时,涉及移动智能终端的本地人脸识别的安全性问题也日渐凸显,如,使用相片或者视频进行欺骗,在终端上的人脸数据被恶意劫持等问题。目前行业中尚未有针对移动终端本地人脸识别的通用的安全要求及测试评估方法,对此没有统一的标准,基于上述考虑,提出移动智能终端人脸识别安全技术要求和相应的测评方法的标准,规范移动智能终端本地人脸识别的安全性要求,为国内该领域的相关产品的测评提供依据,来促进产业的健康稳定发展。

移动智能终端人脸识别安全技术要求及测试评估方法

1 范围

本文件规定了移动智能终端人脸识别的安全技术要求和测试评估方法，包括安全目标、安全威胁分析、安全技术要求、测试评价方法和安全能力分级等。

本文件适用于支持人脸识别技术的移动智能终端，个别条款不适用于特殊行业、专业应用，其他终端也可参考使用。

2 规范性引用文件

下列文件对于本文件的应用是必不可少的。凡是注日期的引用文件，仅所注日期的版本适用于本文件。凡是不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 26238-2010 信息技术 生物特征识别术语

GB/T 37036.3-2019 信息技术 移动设备生物特征识别 第3部分：人脸

3 术语、定义和缩略语

3.1 术语和定义

GB/T 26238-2010界定的以及下列术语和定义适用于本文件。

3.1.1

人脸识别 face recognition

基于个体的人脸特征，对个体进行识别的过程。

[GB/T 37036.3-2019，定义3.1]

3.1.2

人脸特征 face characteristic

可以从个体的人脸信息中提取出的有区别的、可重复的特征信息，从而达到个体自动识别的目的。

注：人脸特征可包括：人脸面部的解剖学特征、五官形态特征、特殊标记特征及人脸部因为手术或整容等人为形成的其他特征等。

[GB/T 37036.3-2019，定义3.2]

3.1.3

人脸数据 face data

本部分对处于任何处理阶段的人脸样本、人脸参考、人脸识别特征项或人脸特征的通称。

3.1.4

人脸采集装置 face capture device

收集人脸识别特征信息并将其转换成人脸样本的装置。

注：人脸采集装置可由若干部件组成，例如，发光源、一个或多个图像传感器等。

[GB/T 37036.3-2019，定义3.4]

3.1.5

人脸样本 face sample

从人脸采集装置获得的模拟的或数字的人脸特征的表示。

[GB/T 37036.3-2019，定义3.5]

3.1.6

人脸识别特征项 face recognition feature

从人脸样本中提取的，用于比对的数值或标记。

3.1.7

人脸模板 face template

参考的人脸识别特征项的集合，已存储的人脸识别特征项的集合。

3.1.8

人脸参考 face reference

用于比对的、属于人脸数据主体的一个或多个已存储的人脸样本、人脸模板或人脸识别模型等。

[GB/T 37036.3-2019，定义3.9]

3.1.9

比对得分 comparison score

通过比对得到的数值（或值集）。

[GB/T 26238-2010，定义2.2.2.3.5]

3.1.10

攻击呈现错误接受率 attack presentation false acceptance rate

在特定场景中，采用攻击呈现手段进行呈现攻击被错误接受为真实人脸呈现的比例。

[GB/T 37036.3-2019，定义3.11]

3.1.11

善意呈现错误拒绝率 bona fide presentation false rejection rate

在特定场景中，真实人脸呈现被错误判定为攻击呈现并被拒绝的比例。

[GB/T 37036.3-2019，定义3.12]

3.2 缩略语

下列缩略语适用于本文件。

APFAR	攻击呈现错误接受率	Attack Presentation False Acceptance Rate
BPFRR	善意呈现错误拒绝率	Bona Fide Presentation False Rejection Rate

FAR	错误接受率	False Accept Rate
FRR	错误拒绝率	False Reject Rate
PAD	呈现攻击检测	Presentation Attack Detection
RPMB	重放保护内存块	Replay Protected Memory Block
RTC	实时时钟	Realtime Clock
SE	安全单元	Secure Element
ST	安全目标	Security Target
TEE	可信执行环境	Trusted Execution Environment
TOE	评估对象	Target of Evaluation

4 移动智能终端人脸识别架构

图1是移动智能终端侧人脸识别系统的基本架构。

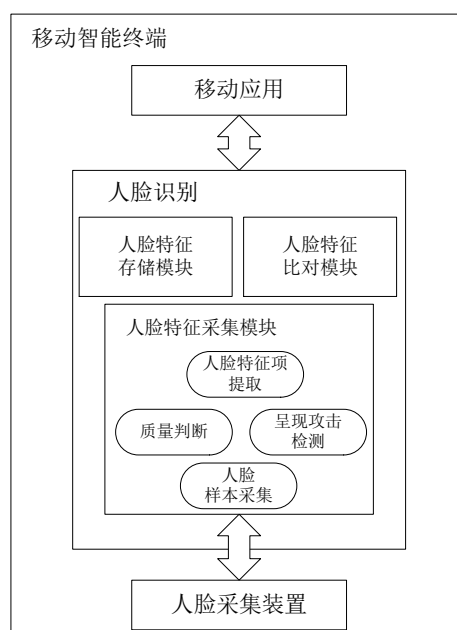


图1 人脸识别架构

移动智能终端人脸识别系统主要包括人脸特征采集模块、人脸特征存储模块和人脸特征比对模块等。其中，人脸特征采集模块负责人脸样本采集、质量判断、呈现攻击检测及人脸识别特征项提取。移动智能终端人脸识别系统的功能一般包括身份注册、身份鉴别、身份识别和身份注销：

——身份注册：通常用户先进行身份注册，由人脸采集装置采集人脸特征，经由人脸特征采集模块将人脸模板经过加密存储在人脸特征存储模块中。

——身份鉴别：通过移动智能终端的人脸采集设备对用户的人脸进行采集，由人脸特征采集模块处理得到人脸识别特征项，使用该人脸识别特征项与用户声称身份所对应的人脸模板在人脸特征比对模块进行比对，验证用户所声称的身份，返回比对判定，比对判定可以为匹配、不匹配或不可确定。

——身份识别：通过移动智能终端的人脸采集设备对用户的人脸进行采集，由人脸特征采集模块处理得到人脸识别特征项，使用该人脸识别特征项与人脸特征存储模块中存储的人脸模板进行逐一比对，产生一组比对得分。

——身份注销：通过移动应用在移动智能终端启动注销，在人脸特征存储模块中删除与待注销用户关联的全部人脸参考，并在人脸识别中删除待注销用户的基于人脸特征的身份标识。

5 性能要求

5.1 识别性能要求

基础要求如下：

- a) 错误接受率不高于 0.01%时，错误拒绝率不高于 10%；

增强要求：

- b) 错误接受率不高于 0.01%时，错误拒绝率不高于 3%。

5.2 呈现攻击检测性能要求

基础要求如下：

- a) 在测试次数不少于一万次、二维与三维攻击样本测试次数之比不高于 9:1 时，攻击呈现错误接受率不高于 5%，善意呈现错误拒绝率不高于 5%；

增强要求：

- b) 在测试次数不少于一万次、二维与三维攻击样本测试次数之比不高于 5:1 时，攻击呈现错误接受率不高于 3%，善意呈现错误拒绝率不高于 3%。

5.3 呈现攻击测试集

移动智能终端人脸识别呈现攻击测试集应包含以下呈现攻击类型及要素：

二维攻击样本类型，应包括但不限于以下因素：

- 打印材质，包括但不限于普通打印纸、哑光相纸、高光相纸、铜版纸等；
- 电子图像的显示设备分辨率、亮度和对比度等；
- 攻击呈现的角度、距离等；
- 静态打印图像、电子图像或动态视频；
- 动态视频是否存在剪辑、拼接或合成；
- 视频图像的清晰度、分辨率、亮度、帧率、人脸尺寸等；
- 遮挡或抠除，二维攻击呈现中包含对眼睛、鼻子和嘴巴等部位的遮挡或抠除；

三维攻击样本类型，应包括但不限于以下因素：

- 面具材质，包括但不限于纸质、塑料、硅胶、石英砂、砂岩、树脂等；
- 头模材质，包括但不限于硅胶、乳胶、泡沫等；
- 攻击呈现的角度、距离等；
- 光线条件，包括但不限于光线强弱、角度、色温等；
- 遮挡或抠除，三维攻击呈现中包含对眼睛、鼻子和嘴巴等部位的遮挡或抠除；
- 面具或头模材质中假眼注视角度。

6 安全技术要求

6.1 采集环节

基础安全功能要求如下：

- c) 人脸采集装置固件应有完整性和可用性保护；
- d) 人脸采集装置驱动程序应有完整性和可用性保护；
- e) 人脸采集装置在人脸样本采集结束后应及时清除人脸样本，并确保其不可恢复；
- f) 人脸样本采集单元应实施访问权限控制，防止人脸样本被窃取；
- g) 人脸识别特征项提取单元的固件应有完整性和可用性保护；
- h) 人脸识别特征项提取单元应保证启动镜像安全，工作在安全模式下；
- i) 人脸识别特征项提取单元所使用的内存应受可信运行环境安全保护或者使用单独物理隔离的内存，不应使用非安全环境的内存；
- j) 在用户申请人脸特征进行身份注册时，应先对用户进行身份验证；
- k) 应设置人脸特征采集的超时或超次处理机制，即在设置的有效时长或有效次数内，如无法采集到符合质量要求的且通过呈现攻击检测的人脸样本时，采集模块自动退出运行。

6.2 传输环节

基础安全功能要求如下：

- a) 人脸识别不同模块间以及模块与应用处理器间进行人脸数据的传输时，应通过安全信道保护数据通信；
- b) 人脸识别不同模块间以及模块与应用处理器间进行人脸数据的传输时，应采取有效安全机制防止重放攻击，如不可预测随机数、时间戳或挑战/应答等方式；

增强安全功能要求：

- c) 人脸采集装置与人脸特征采集模块间应采用安全信道传输；
- d) 人脸样本采集单元生成的人脸样本应使用从 RTC 设备获取的安全时间戳。

6.3 存储环节

基础安全功能要求如下：

- a) 人脸模板应加密存储；
- b) 人脸模板应采用授权访问方式读取；
- c) 应采用有效安全机制，确保对人脸特征存储模块中用户人脸数据进行操作时，用户人脸数据的机密性和完整性；
- d) 在对人脸数据的操作完成后，应对操作过程中产生的临时数据（如存储或传输过程中留存在设备动态内存中的人脸特征样本等数据）及时清除并确保不可恢复；
- e) 人脸模板的更新应在可信运行环境中进行；

增强安全功能要求：

- f) 人脸模板的加密密钥应在安全单元 SE 中存储；
- g) 人脸模板应具备有效的安全机制，防止数据回滚，如：RPMB。

6.4 比对环节

基础安全功能要求如下：

- a) 比对前应对人脸识别特征项进行完整性校验；
- b) 比对模块应采用有效安全机制确保用户人脸数据的保密性和完整性；

- c) 在比对操作完成后，应对比对过程中产生的临时数据（如比对得分等数据）及时清除并确保不可恢复；
 - d) 应设置人脸特征比对的失败尝试次数限制，即在比对失败次数超出限制后，应采取失败处理机制（如退出人脸特征比对模块，采用其他身份认证方式）；
- 增强安全功能要求如下：
- e) 比对过程应在独立的逻辑域或物理域中实现，确保识别比对过程相关数据（如比对得分、阈值和比对判定等数据）的完整性。

6.5 销毁环节

基础安全功能要求如下：

- a) 还原所有设置时，应清除人脸模板数据；
- b) 恢复出厂设置时，应清除人脸模板数据；
- c) 当移动终端被设置为无密码锁屏时，应清除人脸模板数据；
- d) 清除人脸模板数据前应先对用户进行身份验证；

增强安全功能要求如下：

- e) 被清除的数据应采用有效的安全机制，防止数据回滚。

7 测试评估方法

7.1 性能测试

7.1.1 识别性能

测试编号：7.1.1.1
测试项目：错误拒绝率（FRR）
项目要求：5.1 a)
预置条件：被测移动终端恢复出厂设置且处于正常工作状态，可参考附录A构建识别率测试集
测试步骤： - 步骤1：选择识别率测试集中一个人的全部照片，在本组照片内进行识别比对测试； - 步骤2：遍历测试集中所有人，重复步骤1，并统计全部的测试次数，记为T； - 步骤3：假设移动终端的比对阈值为TH，前述步骤测试的比对结果为th，输出比对结果th小于比对阈值TH的统计计数M； - 步骤4：FRR即为M与T的比值，输出FRR的百分制数值。
预期结果： 在步骤4后，输出错误拒绝率的值，如小于对应安全级别要求的数值，则该项目评测结果为“未见异常”，评测结束；反之，该项目评测结果为“不符合要求”，评测结束。

测试编号：7.1.1.2
测试项目：错误接受率（FAR）
项目要求：5.1 a)
预置条件：被测移动终端恢复出厂设置且处于正常工作状态，可参考附录A构建识别率测试集
测试步骤： 步骤1：选择识别率测试集中一个人的某一张照片，使用这张照片与其他人的全部照片依次进行比

对测试： 步骤2：遍历测试集中所有照片，重复步骤1，并统计全部的测试次数，记为T； 步骤3：假设移动终端的比对阈值为TH，前述步骤测试的比对结果为th，输出比对结果th大于比对阈值TH的统计计数M； 步骤4：FAR即为M与T的比值，输出FAR的数值。
预期结果： 在步骤4后，输出错误接受率的值，如小于对应安全级别要求的数值，则该项目评测结果为“未见异常”，评测结束；反之，该项目评测结果为“不符合要求”，评测结束。

测试编号：7.1.1.3
测试项目：错误拒绝率（FRR）
项目要求：5.1 b)
预置条件：被测移动终端恢复出厂设置且处于正常工作状态，可参考附录A构建识别率测试集
测试步骤： 步骤1：选择识别率测试集中一个人的全部照片，在本组照片内进行识别比对测试； 步骤2：遍历测试集中所有人，重复步骤1，并统计全部的测试次数，记为T； 步骤3：假设移动终端的比对阈值为TH，前述步骤测试的比对结果为th，输出比对结果th小于比对阈值TH的统计计数M； 步骤4：FRR即为M与T的比值，输出FRR的百分制数值。
预期结果： 在步骤4后，输出错误拒绝率的值，如小于对应安全级别要求的数值，则该项目评测结果为“未见异常”，评测结束；反之，该项目评测结果为“不符合要求”，评测结束。

测试编号：7.1.1.4
测试项目：错误接受率（FAR）
项目要求：5.1 b)
预置条件：被测移动终端恢复出厂设置且处于正常工作状态，可参考附录A构建识别率测试集
测试步骤： 步骤1：选择识别率测试集中一个人的某一张照片，使用这张照片与其他人的全部照片依次进行比对测试； 步骤2：遍历测试集中所有照片，重复步骤1，并统计全部的测试次数，记为T； 步骤3：假设移动终端的比对阈值为TH，前述步骤测试的比对结果为th，输出比对结果th大于比对阈值TH的统计计数M； 步骤4：FAR即为M与T的比值，输出FAR的数值。
预期结果： 在步骤4后，输出错误接受率的值，如小于对应安全级别要求的数值，则该项目评测结果为“未见异常”，评测结束；反之，该项目评测结果为“不符合要求”，评测结束。

7.1.2 呈现攻击检测性能

测试编号：7.1.2.1
测试项目：攻击呈现错误接受率（APFAR）
项目要求：5.2 a)

预置条件：被测移动终端恢复出厂设置且处于正常工作状态，按照第5.3节的要求构建呈现攻击测试集 测试步骤： 步骤1：选择攻击样本集中的一个样本，使用被测移动终端对样本进行测试； 步骤2：遍历样本集中所有样本，重复步骤1，并统计全部的测试次数，记为T； 步骤3：统计移动终端返回结果为真人的次数，记为M； 步骤4：APFAR即为M与T的比值，输出APFAR的百分制数值。 预期结果： 在步骤4后，输出攻击呈现错误接受率的值，如小于对应安全级别要求的数值，且二维与三维攻击样本测试次数之比不高于9:1时，则该项目评测结果为“未见异常”，评测结束；反之，该项目评测结果为“不符合要求”，评测结束。
--

测试编号：7.1.2.2
测试项目：善意呈现错误拒绝率（BPFRR）
项目要求：5.2 a)
预置条件：被测移动终端恢复出厂设置且处于正常工作状态，按照第5.3节的要求构建呈现攻击测试集 测试步骤： 步骤1：使用真人对移动智能终端进行测试； 步骤2：遍历符合要求的真人，重复步骤1，并统计全部的测试次数，记为T； 步骤3：统计移动终端返回结果为假人的次数，记为M； 步骤4：BPFRR即为M与T的比值，输出BPFRR的数值。 预期结果： 在步骤4后，输出善意呈现错误拒绝率的值，如小于对应安全级别要求的数值，则该项目评测结果为“未见异常”，评测结束；反之，该项目评测结果为“不符合要求”，评测结束。

测试编号：7.1.2.3
测试项目：攻击呈现错误接受率（APFAR）
项目要求：5.2 b)
预置条件：被测移动终端恢复出厂设置且处于正常工作状态，按照第5.3节的要求构建呈现攻击测试集 测试步骤： 步骤1：选择攻击样本集中的一个样本，使用被测移动终端对样本进行测试； 步骤2：遍历样本集中所有样本，重复步骤1，并统计全部的测试次数，记为T； 步骤3：统计移动终端返回结果为真人的次数，记为M； 步骤4：APFAR即为M与T的比值，输出APFAR的百分制数值。 预期结果： 在步骤4后，输出攻击呈现错误接受率的值，如小于对应安全级别要求的数值，且二维与三维攻击样本测试次数之比不高于5:1时，则该项目评测结果为“未见异常”，评测结束；反之，该项目评测结果为“不符合要求”，评测结束。

测试编号：7.1.2.4
测试项目：善意呈现错误拒绝率（BPFRR）
项目要求：5.2 b)
预置条件：被测移动终端恢复出厂设置且处于正常工作状态，按照第5.3节的要求构建呈现攻击测试集

测试步骤： 步骤1：使用真人对移动智能终端进行测试； 步骤2：遍历符合要求的真人，重复步骤1，并统计全部的测试次数，记为T； 步骤3：统计移动终端返回结果为假人的次数，记为M； 步骤4：BPFRR即为M与T的比值，输出BPFRR的数值。
预期结果： 在步骤4后，输出善意呈现错误拒绝率的值，如小于对应安全级别要求的数值，则该项目评测结果为“未见异常”，评测结束；反之，该项目评测结果为“不符合要求”，评测结束。

7.2 安全测评

7.2.1 采集环节

测试编号：7.2.1.1
测试项目：人脸采集装置固件安全
项目要求：6.1 a)
预置条件：被测移动终端使用原有的人脸采集装置固件文件可以正常启动并正常运行；厂商需提供原有人脸采集装置固件文件、未签名固件文件及固件刷写工具
测试步骤： 步骤1：审查厂商提交的文档，检查固件文件生成方案中是否具备完整性及签名信息； 步骤2：将固件文件进行离线修改，制作满足下面两类要求的固件文件： 1) 以二进制形式打开固件文件，并修改固件文件中的部分字符串内容，破坏原固件文件的完整性，生成完整性被破坏的固件文件； 2) 使用其他签名密钥对未签名的固件文件进行签名，生成签名错误的固件文件； 步骤3：将步骤2生成的两个固件文件刷写到设备上，启动设备，查看设备是否能正常启动。
预期结果： 在步骤1后，如人脸采集装置固件文件的生成方案中不具备完整性及签名信息，则该项目评测结果为“不符合要求”，评测结束； 在步骤3后，如刷写完整性被破坏的固件文件后，设备能正常启动，则该项目评测结果为“不符合要求”，评测结束； 在步骤3后，如刷写签名错误的固件文件后，设备能正常启动，则该项目评测结果为“不符合要求”，评测结束； 在步骤3后，如刷写两个固件文件后，设备都无法正常启动，则该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.1.2
测试项目：人脸采集装置驱动程序安全
项目要求：6.1 b)
预置条件：被测移动终端使用原有的人脸采集装置驱动程序文件可以正常启动并正常运行；厂商需提供原有人脸采集装置驱动程序文件、未签名驱动程序文件及刷写工具
测试步骤： 步骤1：审查厂商提交的文档，检查人脸采集装置驱动程序文件生成方案中是否具备完整性及签名信息； 步骤2：将人脸采集装置驱动程序文件进行离线修改，制作满足下面两类要求的驱动程序文件：

1) 以二进制形式打开驱动程序文件，修改驱动程序文件中的部分字符串内容，破坏原驱动程序文件的完整性，生成完整性被破坏的驱动程序文件； 2) 使用其他签名密钥对未签名的驱动程序文件进行签名，生成签名错误的驱动程序文件； 步骤3：将步骤2生成的两个驱动程序文件刷写到设备上，启动设备，查看设备是否能正常启动。
预期结果： 在步骤1后，如移动终端人脸采集装置驱动程序文件生成方案中不具备完整性及签名信息，则该项目评测结果为“不符合要求”，评测结束； 在步骤3后，如刷写完整性被破坏的驱动程序文件后，设备能正常启动，则该项目评测结果为“不符合要求”，评测结束； 在步骤3后，如刷写签名错误的驱动程序文件后，设备能正常启动，则该项目评测结果为“不符合要求”，评测结束； 在步骤3后，如刷写两个驱动程序文件后，设备都无法正常启动，则该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.1.3
测试项目：人脸样本采集单元访问控制
项目要求：6.1 c)
预置条件：被测移动终端处于正常工作状态
测试步骤： 步骤1：审查厂商提交的方案文档，检查移动终端人脸样本采集单元是否具备访问权限控制机制； 步骤2：使用不具备采集权限的应用尝试访问人脸样本采集功能。
预期结果： 在步骤1后，如文档内容显示移动终端人脸样本采集功能不具备访问权限控制机制，则该项目评测结果为“不符合要求”，评测结束； 在步骤2后，如不具备人脸样本采集权限的应用可访问采集功能，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.1.4
测试项目：无残留人脸样本数据
项目要求：6.1 d)
预置条件：被测移动终端处于正常工作状态
测试步骤： 步骤1：使用人脸采集装置采集人脸样本； 步骤2：使用具备访问权限的应用访问人脸采集装置中残留的数据，检查其中是否包含人脸样本。
预期结果： 在步骤2后，如具备访问权限的应用从残留数据中读取到人脸样本，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.1.5
测试项目：人脸特征提取单元固件安全
项目要求：6.1 e)
预置条件：被测移动终端使用原有的人脸特征提取单元固件文件可以正常启动并正常运行；厂商需提供

原有人脸特征提取单元固件文件、未签名固件文件及固件刷写工具
测试步骤： 步骤1：审查厂商提交的文档，检查移动终端人脸特征提取单元固件文件生成方案中是否具备完整性及签名信息； 步骤2：将人脸特征提取单元固件文件进行离线修改，制作满足下面两类要求的固件文件： 1) 以二进制形式打开固件文件，修改固件文件中的部分字符串内容，破坏原固件文件的完整性，生成完整性被破坏的固件文件； 2) 使用其他签名密钥对未签名的固件文件进行签名，生成签名错误的固件文件； 步骤3：将步骤2生成的两个固件文件刷写到设备上，启动设备，查看设备是否能正常启动。 预期结果： 在步骤1后，如文档内容显示移动终端人脸特征提取单元固件文件生成方案中不具备完整性及签名信息，则该项目评测结果为“不符合要求”，评测结束； 在步骤3后，如刷写完整性被破坏的固件文件后，设备能正常启动，则该项目评测结果为“不符合要求”，评测结束； 在步骤3后，如刷写签名错误的固件文件后，设备能正常启动，则该项目评测结果为“不符合要求”，评测结束； 在步骤3后，如刷写两个固件文件后，设备都无法正常启动，则该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.1.6
测试项目：人脸特征提取单元镜像安全
项目要求：6.1 f)
预置条件：无
测试步骤： 步骤1：审查厂商提交的文档，检查移动终端人脸特征提取单元启动镜像是否工作在安全模式下； 步骤2：根据方案中显示的安全模式的配置，审核相关源码。 预期结果： 在步骤1后，如文档内容显示移动终端人脸特征提取单元启动镜像未工作在安全模式下，则该项目评测结果为“不符合要求”，评测结束； 在步骤2后，如源码显示移动终端人脸特征提取单元启动镜像工作在安全模式下，则该项目评测结果为“未见异常”，评测结束；反之，该项目评测结果为“不符合要求”，评测结束。

测试编号：7.2.1.7
测试项目：人脸特征提取单元内存安全
项目要求：6.1 g)
预置条件：被测移动终端处于正常工作状态
测试步骤： 步骤1：审查厂商提交的文档，检查人脸特征提取单元使用的内存是否是安全环境的内存； 步骤2：审查厂商提交的文档，获取非安全环境内存地址范围； 步骤3：正常使用人脸特征提取单元处理人脸识别特征项，获取人脸特征提取单元使用的内存地址范围； 步骤4：比较步骤2和步骤3获取的地址范围。

预期结果:

在步骤1后, 如文档内容显示人脸特征提取单元使用的内存是非安全环境的内存, 则该项目评测结果为“不符合要求”, 评测结束;

在步骤4后, 步骤2和步骤3获取的地址范围有交叉, 则该项目评测结果为“不符合要求”, 评测结束; 反之, 该项目评测结果为“未见异常”, 评测结束。

测试编号: 7.2.1.8

测试项目: 用户身份验证

项目要求: 6.1 h)

预置条件: 被测移动终端处于正常工作状态

测试步骤:

步骤1: 审查厂商提交的文档, 检查用户进行人脸特征身份注册时是否需要进行身份验证;

步骤2: 打开人脸特征身份注册界面, 查看移动终端是否通过请求用户输入锁屏密码、指纹等信息验证当前用户身份。

预期结果:

在步骤1后, 如文档内容显示用户进行人脸特征身份注册前不需要进行身份验证, 则该项目评测结果为“不符合要求”, 评测结束;

在步骤2后, 如移动终端未显示提示信息请求用户输入锁屏密码或指纹, 则该项目评测结果为“不符合要求”, 评测结束; 反之, 该项目评测结果为“未见异常”, 评测结束。

测试编号: 7.2.1.9

测试项目: 超时或超次处理机制

项目要求: 6.1 i)

预置条件: 被测移动终端处于正常工作状态

测试步骤:

步骤1: 审查厂商提交的文档, 检查是否有针对采集有效时长或有效次数制定管理策略;

步骤2: 进行人脸特征采集时, 在某个方向多次录入数据, 长时间录入某个方向数据但余留一个方向的数据不录入, 查看移动终端系统的后续处理流程是否满足厂商提交方案中的管理策略。

预期结果:

在步骤1后, 如文档内容显示用户进行人脸特征采集时不具备有效时长或有效次数的管理策略, 则该项目评测结果为“不符合要求”, 评测结束;

在步骤2后, 如超过有效时长或有效次数限制时, 移动终端系统的后续处理流程与厂商提交方案中的管理策略不一致, 则该项目评测结果为“不符合要求”, 评测结束; 反之, 该项目评测结果为“未见异常”, 评测结束。

7.2.2 传输环节

测试编号: 7.2.2.1

测试项目: 安全信道要求

项目要求: 6.2 a)

预置条件: 无

测试步骤:

步骤1: 审查厂商提交的文档, 检查人脸识别不同模块间以及模块与应用处理器之间是否通过安全

信道保护数据通信，该安全信道应保证其他应用无法获取或篡改传输中的数据。
预期结果： 在步骤1后，如文档内容传输未通过安全信道保护数据通信，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.2.2
测试项目：重放保护
项目要求：6.2 b)
预置条件：无
测试步骤： 步骤1：审查厂商提交的文档，检查人脸识别不同模块间以及模块与应用处理器之间的通信是否具备有效的安全机制确保数据不被重放攻击，该机制应包含对数据重放的检测，以及检测到数据被重放时的处理机制。
预期结果： 在步骤1后，如文档内容显示不具备满足要求的安全机制以保护数据不被重放攻击，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.2.3
测试项目：人脸数据传输信道安全
项目要求：6.2 c)
预置条件：无
测试步骤： 步骤1：审查厂商提交的文档，检查人脸采集装置与人脸特征采集模块间是否通过安全信道传输； 步骤2：审核人脸采集装置与人脸特征采集模块间采用安全信道的相关源码，查看其使用的传输信道是否经过富运行环境。
预期结果： 在步骤1后，如文档内容显示人脸采集装置与人脸特征采集模块间不采用安全信道传输人脸数据，则该项目评测结果为“不符合要求”，评测结束； 在步骤2后，如源码中显示人脸采集装置与人脸特征采集模块间传输信道经过富运行环境，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.2.4
测试项目：人脸样本时间戳安全
项目要求：6.2 d)
预置条件：无
测试步骤： 步骤1：审查人脸样本采集单元源码，查看采集人脸样本时是否从RTC设备获取安全时间戳。
预期结果： 在步骤1后，如源码显示人脸样本采集单元生成人脸样本时未从RTC设备获取安全时间戳，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

7.2.3 存储环节

测试编号：7.2.3.1
测试项目：人脸模板加密存储
项目要求：6.3 a)
预置条件：被测移动终端处于正常工作状态
测试步骤： 步骤1：审查厂商提交的文档，检查人脸模板存储机制是否提供加密存储功能； 步骤2：使用人脸模板存储机制API，在一台移动终端A中存入一段模板数据； 步骤3：通过人脸模板存储机制API读取存入的数据； 步骤4：通过直接I/O操作，获取物理存储空间中的数据； 步骤5：比较步骤3和步骤4获取的数据，查看是否有数据内容一致； 步骤6：将步骤4读取的数据复制到另一台移动终端B存储空间中； 步骤7：通过人脸数据存储机制API读取移动终端B中的数据，查看返回数据是否与步骤3获取的数据一致。
预期结果： 在步骤1后，如文档内容显示人脸模板存储机制未提供加密存储功能，则该项目评测结果为“不符合要求”，评测结束； 在步骤5后，如比较的数据内容中有部分内容一致，则该项目评测结果为“不符合要求”，评测结束； 在步骤7后，如读操作成功且获取的数据与步骤3获取的数据内容一致，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.3.2
测试项目：人脸模板访问控制
项目要求：6.3 b)
预置条件：被测移动终端处于正常工作状态
测试步骤： 步骤1：审查厂商提交的文档，检查人脸模板数据是否经过授权方可进行访问读取； 步骤2：在移动终端中录入人脸数据； 步骤3：使用未授权的应用尝试读取人脸模板数据。
预期结果： 在步骤1后，如文档内容显示未设置人脸模板数据授权访问机制，则该项目评测结果为“不符合要求”，评测结束； 在步骤3后，如未授权的应用可以读取人脸数据，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.3.3
测试项目：人脸数据机密性和完整性保护
项目要求：6.3 c)
预置条件：被测移动终端处于正常工作状态
测试步骤： 步骤1：审查厂商提交的文档，检查存储机制是否采用有效安全机制确保人脸数据的机密性和完整性；

步骤2：使用人脸数据存储机制API，在移动终端中存入一段数据； 步骤3：通过直接I/O操作，修改物理存储空间中存储的数据； 步骤4：通过人脸数据存储机制API读取数据。
预期结果： 在步骤1后，如文档中显示人脸数据存储机制未采用有效安全机制保护人脸数据机密性和完整性，则该项目评测结果为“不符合要求”，评测结束； 在步骤4后，如读操作成功，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.3.4
测试项目：无残留临时数据
项目要求：6.3 d)
预置条件：被测移动终端处于正常工作状态
测试步骤： 步骤1：审查厂商提交的文档，检查人脸数据操作完成后，残留的临时数据是否会清除，以及是否会被恢复； 步骤2：在移动终端中录入人脸数据； 步骤3：待人脸数据处理完成后，读取设备动态内存、安全内存中的内容。
预期结果： 在步骤1后，如文档内容显示人脸数据操作完成后临时数据未被清除，则该项目评测结果为“不符合要求”，评测结束； 在步骤3后，如读取的设备动态内存、安全内存中的数据与文档中显示的人脸数据清除后动态内存和安全内存中应有的数据一致，则该项目评测结果为“未见异常”，评测结束；反之，该项目评测结果为“不符合要求”，评测结束。

测试编号：7.2.3.5
测试项目：人脸模板更新安全
项目要求：6.3 e)
预置条件：无
测试步骤： 步骤1：审查厂商提交的文档，检查人脸模板更新是否在可信运行环境中进行； 步骤2：审核人脸模板更新部分的源代码，检查其中操作是否在可信运行环境中进行。
预期结果： 在步骤1后，如文档内容显示人脸模板更新未在可信运行环境中进行，则该项目评测结果为“不符合要求”，评测结束； 在步骤2后，如源码显示人脸模板更新未在可信运行环境中进行，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.3.6
测试项目：密钥安全存储
项目要求：6.3 f)
预置条件：无

测试步骤： 步骤1：审查厂商提交的文档，检查人脸模板加密密钥是否在安全单元SE中存储； 步骤2：审查人脸模板加密处理部分的源码，查看人脸模板的使用是否符合以下两种情况之一： i. 加密时使用的密钥从安全单元SE中获取； ii. 由SE提供人脸模板的加解密功能，密钥不出SE。
预期结果： 在步骤1后，如文档内容显示人脸模板加密密钥不在安全单元SE中存储，则该项目评测结果为“不符合要求”，评测结束； 在步骤2后，如源码显示人脸模板加密时使用的密钥从安全单元SE中获取或由SE直接提供人脸模板的加解密，密钥不出SE，则该项目评测结果为“未见异常”，评测结束；反之，该项目评测结果为“不符合要求”，评测结束。

测试编号：7.2.3.7
测试项目：人脸模板数据防回滚保护
项目要求：6.3 g)
预置条件：被测移动终端处于正常工作状态
测试步骤： 步骤1：审查厂商提交的文档，检查人脸模板存储机制是否采用有效安全机制防止数据回滚； 步骤2：使用人脸模板存储机制API，在移动终端中存入一段数据； 步骤3：通过直接I/O操作，将物理存储空间中的存储数据备份； 步骤4：使用人脸模板存储机制API，修改之前存储的数据； 步骤5：通过直接I/O操作，将之前备份的数据覆盖修改后的数据； 步骤5：使用人脸模板存储机制API，读取存储的数据。
预期结果： 在步骤1后，如文档内容显示人脸模板数据存储机制未采用有效安全机制防止数据回滚，则该项目评测结果为“不符合要求”，评测结束； 在步骤5后，如读取操作成功，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

7.2.4 比对环节

测试编号：7.2.4.1
测试项目：人脸识别特征项完整性校验
项目要求：6.4 a)
预置条件：被测移动终端处于正常工作状态
测试步骤： 步骤1：审查厂商提交的文档，检查人脸特征比对模块是否对输入的人脸识别特征项进行完整性校验； 步骤2：录入人脸特征，并通过直接I/O操作进行人脸识别特征项的修改和录入； 步骤3：检验人脸特征比对模块是否执行正常比对过程。
预期结果： 在步骤1后，如文档中显示人脸特征比对模块未进行人脸识别特征项的完整性校验，则该项目评测结果为“不符合要求”，评测结束；

在步骤3后，如比对操作成功，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.4.2

测试项目：人脸数据的保密性和完整性

项目要求：6.4 b)

预置条件：被测移动终端处于正常工作状态

测试步骤：

步骤1：审查厂商提交的文档，检查人脸特征比对模块是否采用有效安全机制确保人脸数据的机密性和完整性；

步骤2：使用人脸数据存储机制API，在移动终端中存入一段数据；

步骤3：通过直接I/O操作，修改比对模块中的人脸数据；

步骤4：通过API读取比对模块中的数据。

预期结果：

在步骤1后，如文档中显示人脸特征比对模块未采用有效安全机制保护人脸数据机密性和完整性，则该项目评测结果为“不符合要求”，评测结束；

在步骤4后，如读操作成功，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.4.3

测试项目：无残留临时数据

项目要求：6.4 c)

预置条件：被测移动终端处于正常工作状态

测试步骤：

步骤1：审查厂商提交的文档，检查人脸特征比对操作完成后，残留的临时数据（如比对得分）是否会清除，以及是否会被恢复；

预期结果：

在步骤1后，如文档内容显示人脸特征比对数据操作完成后临时数据未被清除，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.4.4

测试项目：失败尝试次数限制机制

项目要求：6.4 d)

预置条件：被测移动终端处于正常工作状态

测试步骤：

步骤1：审查厂商提交的文档，检查是否有针对人脸特征比对的失败尝试次数限制机制；

步骤2：进行人脸特征比对时，采用非授权人的人脸特征进行比对，多次尝试后查看移动终端系统的后续处理流程是否满足厂商提交方案中的管理策略。

预期结果：

在步骤1后，如文档内容显示用户进行人脸特征比对时不具备失败尝试次数限制机制，则该项目评测结果为“不符合要求”，评测结束；

在步骤2后，如超过失败尝试有效次数限制时，移动终端系统的后续处理流程与厂商提交方案中的

管理策略不一致，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.4.5

测试项目：比对过程安全

项目要求：6.4 e)

预置条件：被测移动终端处于正常工作状态

测试步骤：

步骤1：审查厂商提交的文档，检查比对过程是否在独立的逻辑域或物理域实现；

步骤2：审查人脸特征比对模块的源码，查看比对过程是否在独立的逻辑域或物理域实现。

预期结果：

在步骤1后，如文档中显示比对过程不在独立的逻辑域或物理域，则该项目评测结果为“不符合要求”，评测结束；

在步骤4后，如源代码显示比对过程不在独立的逻辑域或物理域，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

7.2.5 销毁环节

测试编号：7.2.5.1

测试项目：还原所有设置时人脸模板数据销毁

项目要求：6.5 a)

预置条件：被测移动终端处于正常工作状态

测试步骤：

步骤1：在被测移动终端中录入人脸模板数据；

步骤2：打开被测移动终端设置界面，选择还原所有设置；

步骤3：将被测移动终端重启，查看人脸模板数据存储目录下是否有数据残留。

预期结果：

在步骤3后，如人脸模板数据存储目录下有数据残留，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.5.2

测试项目：恢复出厂设置时人脸模板数据销毁

项目要求：6.5 b)

预置条件：被测移动终端处于正常工作状态

测试步骤：

步骤1：在被测移动终端中录入人脸模板数据；

步骤2：打开被测移动终端设置界面，选择恢复出厂设置；

步骤3：将被测移动终端重启，查看人脸模板数据存储目录下是否有数据残留。

预期结果：

在步骤3后，如人脸数据存储目录下有数据残留，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.5.3

测试项目：设置无密码锁屏时人脸模板数据销毁
项目要求：6.5 c)
预置条件：被测移动终端处于正常工作状态
测试步骤： - 步骤1：在被测移动终端中录入人脸模板数据； - 步骤2：打开被测移动终端设置界面，选择删除锁屏密码； - 步骤3：将被测移动终端重启，查看人脸模板数据存储目录下是否有数据残留。
预期结果： 在步骤2后，如人脸模板数据存储目录下有数据残留，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.5.4
测试项目：用户身份验证
项目要求：6.5 d)
预置条件：被测移动终端处于正常工作状态
测试步骤： - 步骤1：审查厂商提交的文档，检查用户清除人脸模板数据前是否需要进行身份验证； - 步骤2：逐一进行还原所有设置、恢复出厂设置和取消锁屏密码的操作，查看移动终端是否通过请求用户输入锁屏密码、指纹等信息验证当前用户身份。
预期结果： 在步骤1后，如文档内容显示用户清除人脸模板数据前不需要进行身份验证，则该项目评测结果为“不符合要求”，评测结束； 在步骤2后，如移动终端未显示提示信息请求用户输入锁屏密码或指纹，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

测试编号：7.2.5.5
测试项目：被销毁数据防回滚保护
项目要求：6.5 e)
预置条件：被测移动终端处于正常工作状态，且移动终端可通过人脸识别解锁
测试步骤： - 步骤1：测试人员A使用被测移动终端录入人脸数据； - 步骤2：测试人员A使用人脸识别成功解锁设备； - 步骤3：读取人脸模板数据并进行备份； - 步骤4：打开移动终端设置界面，通过恢复出厂设置等操作删除当前保存的人脸模板数据； - 步骤5：测试人员B使用被测移动终端录入人脸数据； - 步骤6：使用之前备份的人脸模板数据覆盖测试人员B的人脸模板数据； - 步骤7：测试人员A使用被测移动终端进行人脸识别解锁。
预期结果： 在步骤6后，如测试人员A成功进行解锁，则该项目评测结果为“不符合要求”，评测结束；反之，该项目评测结果为“未见异常”，评测结束。

8 评估与分级

本文件将移动智能终端人脸识别系统的评估等级划分为依次递增的四个能力等级，在每一等级定义了移动智能终端人脸识别系统对应的技术要求的最小集合。具体的等级划分应符合表 1。

表 1 人脸识别系统评级对照表

技术要求		能力等级			
		一级	二级	三级	四级
识别性能	基础要求	√			
	增强要求		√	√	√
呈现攻击检测性能	基础要求	√	√		
	增强要求			√	√
采集环节	基础安全功能要求	√	√	√	√
传输环节	基础安全功能要求	√	√	√	√
	增强安全功能要求			√	√
存储环节	基础安全功能要求	√	√	√	√
	增强安全功能要求 f)				√
	增强安全功能要求 g)			√	√
比对环节	基础安全功能要求	√	√	√	√
	增强安全功能要求			√	√
销毁环节	基础安全功能要求	√	√	√	√
	增强安全功能要求		√	√	√

附录 A

(资料性附录)

识别率测试集

A.1 概述

本附录定义的识别率测试集可用来对第7.1.1节中的FAR和FRR指标进行评测。

A.2 测试数据

人脸样本的质量与拍摄环境、采集条件、采集对象等因素有关，具体包括样本来源多样性、采集设备、光线条件、姿态角度、年龄跨度、性别、表情、肤色、种族、遮挡等影响因素。为了全面评估人脸识别性能，在构建人脸测试样本集时，尽可能考虑上述各种因素。

A.3 识别率测试集构建原则

识别率测试集构建通常遵循以下原则：

- a) 人脸样本来源于实际应用场景；
- b) 性别分布：男性占 $50\% \pm 3\%$ ，女性占 $50\% \pm 3\%$ ；
- c) 年龄分布：18-30 岁占 25%-40%，31 岁-50 岁占 25%-40%，51 岁-70 岁占 25%-40%，18 岁以下及 70 岁以上不做要求，可根据前述三个年龄段的占比动态调整比例；
- d) 测试样本的组成应考虑样本来源多样性、采集设备、光线条件、姿态角度、年龄跨度、性别、表情、肤色、种族、遮挡等影响人脸识别性能的因素。

A.4 识别率测试集组成

- a) 识别率测试集由两类集合组成，具体包括：
 - 1) 目标集：用于人脸登记的人脸样本测试集；
 - 2) 验证集：用于人脸比对的人脸样本测试集；
 - 3) 目标用户验证集：在目标集中存在对应注册人的人脸验证集；
 - 4) 非目标用户验证集：在目标集中不存在对应注册人的人脸验证集。
- b) 识别率测试集中对人脸样本数量的定义，具体包括：
 - 1) 目标集 ≥ 10000 人，每人 1 幅图像，每幅图像有且仅有一张人脸；
 - 2) 验证集 ≥ 10000 人，包含目标用户验证集和非目标用户验证集，其中，目标用户验证集 ≥ 5000 人，每人 ≥ 1 幅图像，每幅图像有且仅有一张人脸。

参 考 文 献

- ISO/IEC 19795-1-2006 Information technology — Biometric performance testing and reporting — Part 1:Principles and framework
- ISO/IEC 30107 Information technology — Biometric presentation attack detection
- GB/T 26238-2010 信息技术 生物特征识别术语
- GB/T 35273—2017 信息安全技术 个人信息安全规范
- GB/T 37036.3-2019 信息技术 移动设备生物特征识别 第3部分：人脸
- YD/T 2407-2013 移动终端安全能力技术要求
- YD/T 2408-2013 移动终端安全能力测试方法
- TAF-WG4-AS0008-V1.0.0:2017 移动终端安全环境安全评估内容和方法
- TAF-WG4-AS0026-V1.0.0:2018 移动终端基于TEE的人脸识别安全评估方法
-